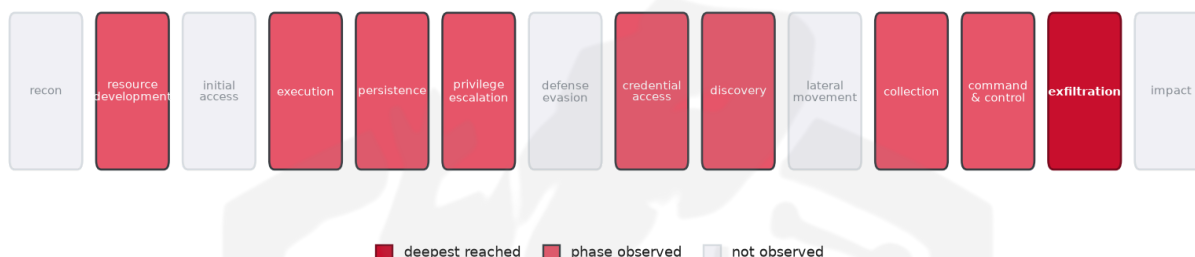


THREAT REPORT: REF9334 LEVERAGES KREMLIN CHROME EXTENSION TO STEAL BANKING SESSIONS

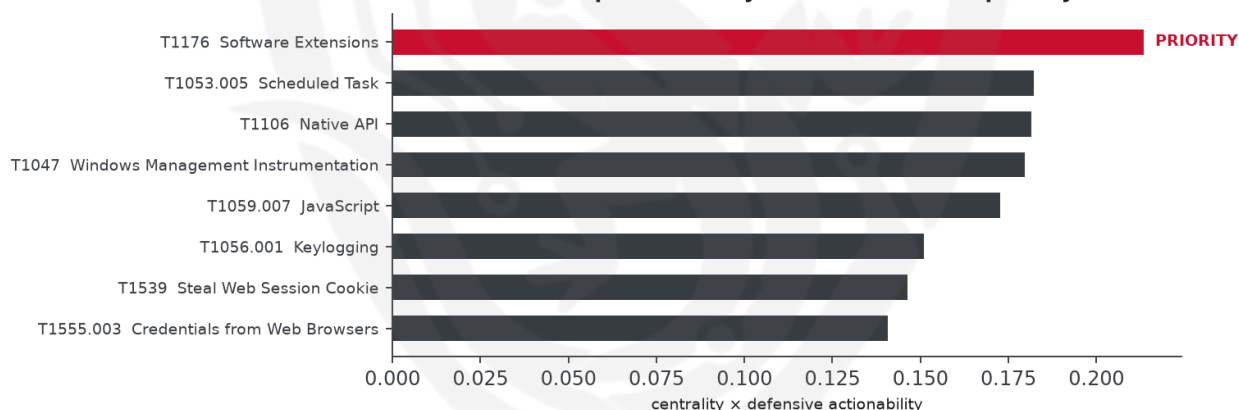
Visual Summary

Kill-Chain Reach — Critical (deepest phase reached: exfiltration)



How far down the attack chain this campaign reached; deepest phase in crimson.

Defensive Chokepoint — why this control is the priority



The control that most disrupts the attack (priority in crimson).

Summary

The threat actor REF9334 is distributing a malicious Chrome extension dubbed KREMLIN, which forges Chrome's integrity checks to capture banking sessions. The campaign employs the Virus:DOS/Kremlin, Trojan:Win32/DoublePulsar, and Remcos-S0332 families against financial institutions in Brazil. No specific CVE is identified in the source material. Priority should be given to applying the MITRE ATT&CK mitigation for the T1176 Software Extensions technique and implementing host- and network-level detections with least-privilege controls.

Threat Overview

REF9334 uses the KREMLIN extension, associated with the Virus:DOS/Kremlin, DoublePulsar, and Remcos malware families, to target the finance sector in Brazil. The source does not cite a concrete

vulnerability (central CVE is listed as Data Insufficient). The activity focuses on hijacking browser sessions and extracting credentials from web browsers.

Attack Chain and Priority Control

The observed chain begins with the delivery of the malicious Chrome extension, followed by masquerading as a legitimate task or service (T1036.004) and matching legitimate resource names (T1036.005). The extension then hijacks execution flow (T1574.002), injects into processes (T1055), and captures screen data (T1113). It proceeds to harvest browser cookies and credentials (T1539, T1555.003, T1185), exfiltrates data over web protocols (T1071.001, T1041), and cleans traces via file deletion (T1070.004).

Priority technique: T1176 Software Extensions

Priority control: Apply the specific MITRE ATT&CK mitigation for this technique; add host/network detections and least-privilege controls around it.

Infrastructure and Corroboration

Third-party analysis shows the command-and-control infrastructure is hosted by RouterHosting LLC. Abuse.ch corroborates the presence of the QuasarRAT malware family on the same infrastructure. No indicators received a confidence rating of 80 % or higher on AbuseIPDB, and the highest confidence observed was 0 %.

Technical Appendix

Ground-truth telemetry from the source pulse; analytical scores are secondary and clearly labelled.

Observed Techniques (ATT&CK, expert-tagged by source)

- T1113 Screen Capture
- T1036.004 Masquerade Task or Service
- T1140 Deobfuscate/Decode Files or Information
- T1001.003 Protocol or Service Impersonation
- T1070.004 File Deletion
- T1574.002 Hijack Execution Flow
- T1105 Ingress Tool Transfer
- T1036.005 Match Legitimate Resource Name or Location
- T1057 Process Discovery
- T1055 Process Injection
- T1185 Browser Session Hijacking
- T1132.001 Standard Encoding
- T1555.003 Credentials from Web Browsers
- T1539 Steal Web Session Cookie
- T1056.001 Keylogging

- T1005 Data from Local System
- T1047 Windows Management Instrumentation
- T1106 Native API
- T1027.002 Software Packing
- T1573.001 Symmetric Cryptography
- T1176 Software Extensions
- T1102.001 Dead Drop Resolver
- T1059.007 JavaScript
- T1119 Automated Collection
- T1033 System Owner/User Discovery
- T1053.005 Scheduled Task
- T1041 Exfiltration Over C2 Channel
- T1071.001 Web Protocols
- T1059.001 PowerShell
- T1217 Browser Information Discovery
- T1083 File and Directory Discovery
- T1082 System Information Discovery
- T1497.001 System Checks
- T1583.001 Domains
- T1560.002 Archive via Library
- T1204.002 Malicious File
- T1518.001 Security Software Discovery

Analytical Scores

- Priority technique (graph chokepoint): T1176 Software Extensions (centrality 0.2257).
- Operational risk: Critical (score 0.968, reaches exfiltration).

Behavioral Signature Cluster

- Method: technique-overlap cosine vs 170 MITRE ATT&CK Groups (top overlap 0.4995; reference threshold $\tau = 0.6$).
- These are behavioural resemblances for defensive playbook cross-referencing, not an identity assessment. Where the source pulse names an actor, that attribution is authoritative; the overlaps below neither confirm nor contest it.

Nearest historical profiles by behavioural overlap (resemblance only):

Historical Profile	Behavioural Overlap
Stealth Falcon	0.4995
Patchwork	0.4972
APT42	0.4962
Gamaredon Group	0.485

Historical Profile	Behavioural Overlap
BRONZE BUTLER	0.4825

Enrichment Signal

- Highest AbuseIPDB confidence among IOCs: 0%.
- Malware families corroborated by abuse.ch: QuasarRAT.
- Note: enrichment raises the severity signal (an IOC at or above 80% AbuseIPDB confidence, or a confirmed malware-family hit). This is context, not a change to the source assessment.

Indicators of Compromise (defanged — non-clickable)

The network and file indicators observed in this activity are listed below for blocklisting:

Type	Indicator	Context
IP	144[.]172[.]112[.]239	AbuseIPDB 0% (US) · AS14956 Router Hosting LLC
IP	178[.]92[.]162[.]38	
IP	185[.]221[.]23[.]133	
IP	37[.]16[.]74[.]100	
IP	37[.]16[.]74[.]34	
IP	45[.]90[.]13[.]210	
Domain	codecaudiog[.]site	
Domain	codecvideowin[.]online	
Domain	zaviro[.]online	
Domain	granderevolucao[.]store	
Domain	volmira[.]site	
Domain	affordableonline[.]online	

Type	Indicator	Context
Domain	cheapzone[.]space	
Domain	lojinhadolui[.]online	
Domain	mysterylink[.]xyz	
URL	hxxps://acrobat-updater[.]com/5f109e7bb3df4dea81946f2f853da288	malware_download
URL	hxxps://acrobat-updater[.]com/generate	malware_download
URL	hxxps://codecvideowin[.]online/af15d5f?p=991589b0-4cc9-11f0-b9f4-1402ec3d56f0	
URL	hxxps://codecvideowin[.]online/f9e95a1e1fa3f3aebfc802c6c8e6a2eb	
Hash	00ea1da4192a2030f9ae023de3b3143ed647bbab	
Hash	2a3ff8f8ea94d4052fe2a7314c4098aa	
Hash	4bc008f4b8da0dd90d282f50030ac78e	
Hash	11306e7cc9aa68fddb63c766d2606d46181af38c	
Hash	1c5454be00f4c3c5aed4a8a54bf81c83e84953a3	
Hash	1df5de857b627b171586b4b0ac800e285faa0c44	
Hash	2ae7494b60277582bd380bc4195964128341f314	
Hash	532511730d540422157dc4284f400b5cc83edeb5	
Hash	6bfef63fd12701f125e49b7d17388e6502b6c090	
Hash	6f7e7a6d99270b2ff330dd0c9707b3b772301104	
Hash	728601a30d22a2ad8514f366cc9cc9d829e9f10a	
Hash	754bf10bc98df84cf6d7ffb19138805642b1979	
Hash	b9c5941aab2889700377dc9d52130d2dcf407146	
Hash	c332e3b49bb9d68e6fc7e9df933c5ba144cce3f8	
Hash	c61bab62a306d5fdb51a991a017fa351186b664b	

Type	Indicator	Context
Hash	fbc6a7525ae1e80342ecf0539026f2375b97b03d	
Hash	12a2974fe4af869fefb66886b4a2a6f34d358a54038c3424635f ee5e5fae111e	
Hash	598764b174f35ca76586bd0036a3caf87538aec52a1f95cf1c4c e25e027cf71f	
Hash	62e0383b93de31204574ab52d136c58469e710ce38d2d7f061 438ab5abbd76f7	QuasarRAT
Hash	1440e142dcf7f00c6385de1ca910210f	QuasarRAT
Hash	902f4f7da9a9fb50ed424915b912a24870a9b854	QuasarRAT

Reputation by AbuseIPDB · malware attribution by abuse.ch · Geo/ASN data by IP2Location LITE.

Flame Cell // Adversary Pivot [BETA]

BETA. A hypothetical tabletop projection, anchored to documented ATT&CK behaviour and technique co-occurrence across 170 tracked groups. It is not a prediction; treat it as a war-game prompt and review before acting. Spot a pivot that looks wrong? norbert@salacti.com

- **Control applied:** T1176 Software Extensions (persistence)
- **Observed here:** REF9334 used T1053.005 Scheduled Task here as an alternative persistence technique.
- **Projected pivot:** T1053.005 Scheduled Task (persistence)
- **Basis:** observed in this campaign (an alternative the actor already demonstrated).

Given the block on software extensions, the adversary could pivot to T1053.005 by creating a scheduled task that launches a PowerShell command or script at system startup or on a recurring timer, thereby achieving persistence without needing a malicious extension and exploiting native Windows scheduling. Defenders should alert on new scheduled tasks (Event ID 4698); restrict schtasks/at to admins; baseline legitimate task creators.

Detection and hardening for the pivot (T1053.005 Scheduled Task/Job)

- **Telemetry:** Windows Security (Object Access audit); Microsoft-Windows-TaskScheduler/Operational; Sysmon
- **Detect:**
 - Security 4698 (task created), 4702 (updated), 4700/4701 (enabled/disabled), 4699 (deleted)
 - TaskScheduler/Operational 106 (registered), 140 (updated), 141 (deleted)
 - Sysmon 1 for schtasks.exe and at.exe; Sysmon 11 for writes under C:\Windows\System32\Tasks\
- **Harden:**

- Restrict schtasks/at to administrators; disable the legacy at.exe
- Baseline the legitimate task creators and alert on anything outside it
- **MITRE:** M1047 Audit, M1028 Operating System Configuration, M1026 Privileged Account Management · DS0003 Scheduled Job, DS0009 Process, DS0022 File

